

“BlueGuard”

A PROJECT REPORT

SUBMITTED BY

Patel Harsh (ET24MTCA044)

UNDER THE GUIDANCE OF

Prof. Zankhana Vaishnav

In fulfilment for the award of the degree

Of

Master of Computer Applications

At



Sarvajanik College of Engineering and Technology, Surat.

Sarvajanik University

May, 2026



Sarvajanik University
Sarvajanik College of Engineering & Technology, Surat.
Department of Computer Applications



Date:
02/05/2026

CERTIFICATE

This is to certify that the project entitled “**BlueGuard**” has been submitted by Patel Harsh (ET24MTCA044) towards the fulfillment of the degree of Master of Computer Applications (M.C.A) in (4th Semester) of Sarvajanik University, Surat during the academic year 2025-2026.

Prof. Zankhana Vaishnav

Dr. Gayatri Kapadia
(Head- Department of Computer
Applications)

(Guide’s Signature)

Examiner’s Signature

1. _____

2. _____

SELF-DECLARATION

Title of the Project: BlueGuard - AI SOC Driven Platform

Enrollment No.	Student Name
ET24MTCA044	Patel Harsh

I hereby declare that the above-mentioned project report submitted by me has been prepared by me and is original in its content and has not been submitted anywhere else.

I confirm that the report is prepared solely for academic requirements and not for any other purpose. It is intended for academic evaluation and might not be used by anyone for any other purpose without prior permission.

Student Signature:

ACKNOWLEDGMENT

The development and ongoing research for the project, "BlueGuard - AI-Driven SOC Platform," has been a rewarding journey of learning and technical discovery. This work has evolved significantly through the guidance and support of many individuals who have contributed their time and expertise.

First and foremost, I would like to express my deepest gratitude to my college mentor, **Prof. Zankhana Vaishnav**, for her continuous encouragement, technical insights, and valuable feedback during the various phases of this project. Her mentorship has been instrumental in refining the technical architecture and academic standards of this work.

I am also sincerely thankful to **Dr. Gayatri Kapadia, Head of the Department (HOD)**, for providing a conducive environment for innovation and for her constant support toward the progress of our academic projects.

I would like to extend my heartfelt thanks to my industry mentors, **Mr. Neel Zaveri and Mr. Mitul Vanasiwala**, for their professional guidance and for sharing their real-world experience in the field of cybersecurity. Their practical advice has been vital in understanding the complexities of a Security Operations Center (SOC) and ensuring that the BlueGuard logic aligns with industry-standard security principles.

Finally, I would like to thank my family and friends for their unwavering support and patience throughout this intensive development process. Their belief in my abilities has been a constant source of motivation as I continue to enhance this platform.

Yours Sincerely,

Patel Harsh (ET24MTCA044)

INDEX

SR.NO	PARTICULAR	PG.NO
1	Introduction	
	1.1 Existing System	1
	1.2 Need for the New System	1
	1.3 Objective of the New System	2
	1.4 Problem Definition	3
	1.5 Core Components	5
	1.6 Project Profile	5
	1.7 Assumptions and Constraints	7
	1.8 Advantages and Limitations of the Proposed System	8
2	Requirement Determination & Analysis	
	2.1 Requirement Determination	11
	2.2 Targeted Users	13
3	System Design	
	3.1 Use Case Diagram	14
	3.2 Class Diagram	15
	3.3 Interaction Diagram	16
	3.4 Activity Diagram	18
	3.5 Data Dictionary	20
4	Development	
	4.1 Coding Standards	22
	4.2 Screen Shots	25
5	Agile Documentation	
	5.1 Agile Project Charter	32
	5.2 Agile Roadmap	33
	5.3 Agile Project Plan	34
	5.4 Agile User Story	36
	5.5 Agile Release Plan	37
	5.6 Agile Sprint Backlog	39
	5.7 Agile Test Plan	40
	5.8 Earned-value and burn charts	45
6	Proposed Enhancements	47
7	Conclusion	50
8	Bibliography	52

1. INTRODUCTION

1.1 Existing System

The traditional Security Operations Center (SOC) framework has relied heavily on Rule-Based detection systems for over two decades. Known as Legacy SIEM (Security Information and Event Management), these systems function by matching incoming logs against pre-defined signatures or static thresholds.

- **Signature-Based Limitations:** Legacy systems can only detect threats that they have been explicitly programmed to find. If a new, "Zero-Day" attack occurs, the system remains blind until a manual update is provided.
- **Extreme Alert Fatigue:** A typical enterprise SOC receives between 5,000 to 10,000 alerts per day. Analysts are overwhelmed by "Noise," leading to significant burnout and the high probability of missing a "Critical" incident hidden among thousands of "Low" priority alerts.
- **Static Severity Scoring:** In existing systems, an alert is assigned a severity level based on a generic global standard. For example, a "Suspicious Login" might be marked as High. However, if that login happens on a guest machine with no access to sensitive data, the risk is actually Low. Legacy systems cannot make this distinction.
- **Manual Investigative Overhead:** Once an alert is triggered, an analyst must manually cross-reference IP addresses, look up CVE databases, check MITRE frameworks, and search for remediation steps. This manual process takes minutes, while modern attacks execute in milliseconds.

1.2 Need for the new System

As cyber threats evolve into autonomous, AI-driven malware and sophisticated ransomware worms (like WannaCry and LockBit), the defensive layer must also evolve. There is a desperate need for a system that doesn't just "detect" but also "reasons."

- The Reasoning Layer: We need a system that acts as a "Digital SOC Analyst." It should look at an alert and ask: "Is this asset critical? Is it protected by a firewall? Is there a CVE associated with this software?"
- Context-Aware Analysis: The modern SOC needs a system that understands the organization's internal architecture. If a server is air-gapped, the risk of an internet-based exploit reaching it is near zero. The new system must factor this in to reduce false positives.
- Knowledge Integration: Instead of an analyst searching for "CVE-2024-XXXX" manually, the system should automatically fetch the vulnerability details, its CVSS score, and its remediation steps using LLM intelligence.
- Automation of Triage: The primary need is to automate the "Triage" phase—the process of sorting alerts by priority—so that humans only focus on the top 1% of genuine threats.

1.3 Objective of the new System

The primary objective of BlueGuard is to revolutionize the entry-level SOC by providing a high-intelligence monitoring layer at a fraction of the cost of traditional managed security services.

Technical Objectives:

- Seamless SIEM Integration: To build a robust pipeline that ingests data from Wazuh Open-Source SIEM and enriches it in real-time.
- AI-Risk Scoring: To implement a context-aware risk assessment engine that adjusts the severity of alerts based on internal security controls (Firewalls, Network Zones, Privileges).
- Database Persistence: To store all enriched security incidents in a NoSQL database (MongoDB) for long-term forensics and audit logging.

Operational Objectives :

Reduction in Response Time (MTTR): To decrease the Mean Time To Respond from minutes to seconds by providing instant AI-driven remediation steps.

Simplification of UX: To provide a visual dashboard that translates complex technical logs into human-understandable "Incident Stories."

1.4 Problem Definition

In the current digital landscape, cybersecurity is no longer a luxury but a fundamental necessity for organizational survival. However, the methods used to monitor and secure digital assets have not kept pace with the sophistication of modern adversaries. The core problem that leads to the development of BlueGuard can be broken down into four critical dimensions:

1.4.1 The Signal-to-Noise Ratio (The "Data Deluge" Problem)

Modern enterprises generate millions of logs every single hour—from firewalls, servers, databases, and endpoints. Tools like Wazuh and other SIEMs are excellent at collecting this data. However, the problem arises when these tools generate "Alerts."

- The Problem: Out of 10,000 alerts generated daily, typically 98% are false positives or "Informational" noise (e.g., a legitimate admin logging in at an unusual time).
- The Consequence: Human analysts suffer from "Alert Fatigue." When the human brain is bombarded with thousands of non-critical notifications, it starts ignoring them. This leads to a catastrophic "Missed Detection" where a genuine ransomware attack is ignored because it looked like another routine log entry.

1.4.2 Context-Blind Risk Assessment (The "Generic Scoring" Problem)

Currently, a security vulnerability (CVE) is assigned a CVSS score (e.g., 9.8 Critical) globally.

- The Problem: Traditional security systems apply this 9.8 score to every server in the organization, regardless of where that server sits.
- The Reality: If a server is behind three layers of firewalls, has no internet access, and contains no sensitive data, a vulnerability on that server is effectively a Low risk for the organization. Conversely, a 5.0 Medium vulnerability on a public-facing web server is a Critical risk.

- The Gap: Current systems are "Context-Blind." They do not understand the organizational layout, network zones, or existing security controls (like Next Gen Firewalls or internal segmentation).

1.4.3 The Cybersecurity Talent Gap (The "Expertise" Problem)

Analyzing a security log requires a high level of expertise. An analyst must understand MITRE ATT&CK tactics, know how to interpret raw hex data, and be familiar with thousands of CVE identifiers.

- The Problem: Experienced SOC analysts are rare and extremely expensive to hire. Small and medium enterprises (SMEs) cannot afford a 24/7 team of senior experts.
- The Consequence: Many organizations buy expensive SIEM tools like Wazuh but fail to derive value from them because they don't have the "Intelligence" to interpret what the logs are saying.

1.4.4 Delayed Response and High MTTR (The "Time" Problem)

When a breach occurs, every second counts. The "Mean Time to Respond" (MTTR) is a critical metric for any SOC.

- The Problem: In a manual system, when an alert triggers, the analyst must:
 - Read the log.
 - Search Google/databases for the attack type.
 - Identify the affected software.
 - Find the remediation steps.
 - Execute the fix.
- The Bottleneck: This entire manual chain takes anywhere from 15 to 45 minutes per alert. In the age of automated worm-like malware (Ransomware), a system can be fully encrypted in less than 5 minutes. The human-manual response is simply too slow to stop modern threats.

1.4.5 Lack of Actionable Remediation (The "What Now?" Problem)

Most monitoring tools tell you what happened but they don't tell you how to fix it.

- The Problem: A log might say "Buffer Overflow Detected." For a junior analyst, this doesn't tell them what commands to run or what services to stop.
- The Gap: There is a lack of "Actionable Intelligence" at the point of detection. Without immediate, step-by-step instructions, the detection becomes a liability rather than an asset.

1.5 Core Components

- Wazuh SIEM Layer: Responsible for log collection from endpoints (Windows, Linux, Cloud). It provides the "Raw Signal."
- Analysis Middleware (Flask & analyzer.py): The gateway that receives alerts via webhooks and passes them to the AI Engine.
- Generative AI Engine (Gen LLM): The core brain that analyzes the alert, identifies MITRE techniques, fetches CVE data, and calculates "Org Risk."
- Data Storage (MongoDB): The persistent memory of the system, storing every analyzed incident for future reporting.
- Intelligence Dashboard (Glassmorphism UI): The interface for SOC analysts to view the live threat stream, filtered by severity and attack type.

1.6 Project Profile

Feature	Detail
System Name	BlueGuard
Operating System	Platform Agnostic (Compatible with Linux/Windows/Docker)
Backend Language	Python 3.10+(Flask Framework)
AI intergration	Gen LLM
Log Source	Wazuh Manager v4.14.5
Database	Mongo DB

Frontend Styling	Tailwind CSS with Dark glassmorphism design
Alerting Protocol	SMTP Secure Email Notification

The BlueGuard project is structured into five core technical layers. Each layer has a specific responsibility and uses specialized technologies to ensure the platform's overall stability and intelligence.

1.6.1 Data Ingestion Layer (Wazuh SIEM)

- **Role:** This layer acts as the "Senses" of the system. It continuously monitors endpoints for any suspicious activity like unauthorized logins, file integrity changes, or malware execution.
- **Technical Detail:** It uses the Wazuh manager's internal engine to convert raw system logs into structured JSON alerts.

1.6.2 Middleware & Routing Layer (Flask & Webhooks)

- **Role:** This is the "Central Nervous System." It provides a RESTful API endpoint that stays "Alive" 24/7 to catch incoming security signals.
- **Technical Detail:** It uses the Flask framework to handle asynchronous HTTP POST requests. It performs the first level of "Sanitization" to ensure that the incoming data is not malicious.

1.6.3 Cognitive Analysis Layer (Gen LLM Engine)

- **Role:** This is the "Brain" of BlueGuard. It performs complex reasoning that traditional code cannot do.
- **Technical Detail:** By using Prompt Engineering, it injects the organization's specific security context (Firewalls, Isolated VLANs) into the analysis. It classifies the attack type and maps it to the MITRE ATT&CK framework automatically.

1.6.4 Persistence Layer (MongoDB)

- Role: This is the "Memory" of the platform.
- Technical Detail: Unlike traditional SQL databases, MongoDB (NoSQL) allows us to store the "Enriched Intelligence" without losing the original raw log. This is crucial for forensic investigations where the original evidence must be preserved alongside the AI's opinion.

1.6.5 Visualization & User Experience Layer (Tailwind CSS)

- Role: This is the "Face" of the system.
- Technical Detail: It uses a Glassmorphism design system to reduce the visual stress on SOC analysts. By using color-coded severity badges and paginated streams, it ensures that the analyst is never overwhelmed by data.

1.7 Assumptions and Constraints :

1.7.1 Project Assumptions

Assumptions are factors that we consider to be true for the project to succeed.

- Infrastructure Readiness: It is assumed that the target organization has already deployed Wazuh agents on their critical servers (Windows/Linux).
- Network Visibility: We assume the Wazuh Manager has the necessary permissions to transmit alerts to the BlueGuard middleware via port 5000.
- Data Quality: It is assumed that the logs generated by endpoints contain sufficient descriptive data for the AI to perform a meaningful analysis.
- Static Security Policy: We assume that the organizational security controls (e.g., Firewall rules) provided to the AI are accurate and up-to-date.

1.7.2 Technical & Operational Constraints

Constraints are the limitations within which the BlueGuard platform must operate.

- API Latency & Throughput: The system relies on third-party Gen AI APIs. This introduces a mandatory network latency of 2-5 seconds per alert. The system cannot

process alerts in "True Real-Time" (sub-millisecond) due to this external dependency.

- **Outbound Connectivity Requirement:** The AI engine requires an active internet connection to communicate with the LLM models. This makes the platform unsuitable for "Air-Gapped" or "Dark Site" facilities without a local LLM deployment.
- **Token Usage Economics:** Every analysis consumes "Tokens." In an environment with extremely high log volume (e.g., millions of alerts per hour), the operational cost of the API could become a significant constraint.
- **Model Hallucination Risk:** While AI is highly intelligent, there is a non-zero risk of "Hallucination" where the AI might misinterpret an obscure log. To mitigate this, the system includes a "Safety Override" logic.

1.7.3 Environmental Constraints

- **Platform Dependency:** The system requires a host with Python 3.10+ and a local MongoDB instance. Environments without these runtimes will require Docker containerization.
- **Hardware Resources:** For optimal performance, the server must have at least 8GB of RAM to handle concurrent JSON parsing and database writes efficiently.

1.8 Advantages and Limitations :

The BlueGuard AI SOC Platform offers a transformative approach to cybersecurity monitoring. By integrating Generative AI with traditional SIEM data, it provides several layers of benefits that traditional systems cannot match.

1.8.1 Technical Advantages

- **AI-Driven Contextual Intelligence:** Unlike static systems, BlueGuard uses LLMs to understand the "Intent" behind a log, not just the pattern. This allows it to detect "Low and Slow" attacks that often bypass signature-based tools.
- **Automated MITRE ATT&CK Mapping:** Every incident is automatically mapped to the global MITRE framework (Tactics & Techniques). This helps security teams

understand the exact stage of the attack (e.g., Persistence, Lateral Movement, or Exfiltration).

- **Real-Time Data Enrichment:** Raw logs are instantly enriched with CVE data, CWE categories, and CVSS scores. This eliminates the need for manual research by SOC analysts.
- **NoSQL Scalability:** By using MongoDB, the system can handle large volumes of unstructured security logs without the performance bottlenecks found in traditional relational databases.
- **Dynamic Risk Calculation:** The "Org Risk" engine dynamically lowers the priority of threats that are already blocked by internal controls (like Firewalls), ensuring that analysts only work on real, unmitigated threats.

1.8.2 Operational Advantages

- **Reduction in Alert Fatigue:** By filtering out 80-90% of false positives through AI reasoning, BlueGuard prevents analyst burnout and ensures that critical alerts are never missed.
- **Drastic Reduction in MTTR:** The "Mean Time to Respond" is reduced because every alert comes with instant, actionable remediation steps. Analysts don't have to think "What do I do next?"; the system tells them.
- **24/7 Virtual Analyst:** The AI engine works around the clock, providing the same level of analysis at 3:00 AM as it does at 3:00 PM, without human error or fatigue.
- **Simplified Reporting:** The dashboard converts complex technical logs into simple, human-readable summaries that can be understood even by non-technical managers.

1.8.3 Financial & Strategic Advantages

- **Cost-Effective Security:** BlueGuard is built on top of Open-Source Wazuh, saving organizations thousands of dollars in annual licensing fees for commercial SIEMs like Splunk or QRadar.
- **Closing the Skill Gap:** It allows junior SOC analysts to perform at the level of senior experts by providing them with AI-generated technical insights and guidance.

- **High ROI on Existing Infrastructure:** It enhances the value of existing security investments (like Wazuh agents and Firewalls) by making the data they generate actually useful and actionable.

1.8.4 User-Centric Advantages (UX/UI)

- **Glassmorphism Dashboard:** A modern, premium interface that provides high-level visibility (Charts and Graphs) as well as deep-dive forensic logs in a single unified view.
- **Interactive Intelligence:** Clickable CVE/CWE links allow analysts to instantly jump to the official NVD or MITRE documentation for detailed research.
- **Pagination and Search:** Efficient data management allows for smooth navigation through thousands of historical alerts without UI lag.

1.8.5 Limitations of the Proposed System

- **API Dependency:** The core intelligence layer depends on LLM APIs. If the API service is down, the system falls back to a basic rule-based analysis.
- **Internet Requirement:** For the AI Engine to function, the server requires an outbound internet connection, which might be a constraint in highly restricted "Dark Sites."
- **Token Cost:** While the platform is open-source, the usage of AI APIs involves a small cost-per-alert (tokens), which must be managed for extremely high-volume environments.

2. REQUIREMENT DETERMINATION & ANALYSIS

2.1 Requirement Determination

Requirement determination is a critical phase of the SDLC where we define exactly what the system must achieve to solve the identified problems. For BlueGuard, we have categorized requirements into functional, non-functional, and environmental specifications.

2.1.1 Functional Requirements (FRs)

Functional requirements define the core behavior and features of the BlueGuard platform.

- **Real-Time Data Ingestion Pipeline:** The system must provide a highly available /webhook endpoint. This endpoint must be capable of receiving high-frequency POST requests from the Wazuh Manager. It should include error-handling logic to ensure that if a payload is malformed, the system does not crash and continues to process subsequent alerts.
- **Autonomous Threat Analysis (AI Engine):** The system must automatically extract key metadata from raw logs (e.g., Rule ID, Description, Agent Name). This data must be transformed into a structured prompt and sent to a Generative AI model. The engine must ensure that the AI returns data in a strict JSON format for consistent UI rendering.
- **Context-Aware Risk Scoring:** A core requirement is the integration of "Organizational Security Controls." The system must inject predefined infrastructure knowledge (e.g., "All servers are internal," "Palo Alto Firewall is active") into the analysis loop. The AI must use this context to calculate an "Adjusted Org Risk" score that is different from the global "Base Severity."
- **Persistent Storage and Forensics:** Every analyzed alert, along with its AI-generated insights (CVEs, MITRE mapping, Remediation), must be stored in a NoSQL MongoDB database. The system must support complex queries to allow the dashboard to fetch alerts based on severity, agent name, or time range.
- **Dynamic Visual Dashboard:** The frontend must provide a real-time "Threat Stream." It must use dynamic CSS classes to color-code alerts based on their risk

level (Red for Critical, Orange for High, Yellow for Medium, Green for Low). It must also visually represent "Risk Mitigation" using clear indicators (e.g., a "Mitigated" badge with a downward arrow).

- **Server-Side Pagination:** To maintain performance as the database grows to thousands of records, the system must implement server-side pagination. Instead of loading all data at once, the backend must fetch and display only 10-20 records per page, providing a smooth navigation experience for the analyst.
- **Data Export and Compliance:** For audit and reporting purposes, the system must include a "CSV Export" feature. This allows the SOC manager to download the entire incident history in a structured format that can be opened in Excel or PowerBI.
- **Automated Notification System:** The system must monitor incoming alerts and trigger an SMTP email notification whenever a "Critical" or "High" risk incident is detected, ensuring that security teams are alerted even if they are not monitoring the dashboard.

2.1.2 Non-Functional Requirements (NFRs)

Non-functional requirements define the quality attributes of the system.

- **Performance and Latency:** The system should aim for an end-to-end analysis time (from log ingestion to dashboard appearance) of less than 5 seconds. This includes the time taken for the external LLM API call.
- **Scalability:** The architecture must be scalable. By using MongoDB (NoSQL) and a lightweight Flask backend, the system should be able to handle hundreds of alerts per hour without significant degradation in response time.
- **Usability (User Experience):** The dashboard must follow "Clean Design" principles. A SOC analyst should be able to understand the nature of a threat and its remediation steps within 10 seconds of glancing at the screen.
- **Security and Privacy:** The system must ensure that the connection between Wazuh and the Webhook is secure. Furthermore, API keys for LLM must be stored in protected environment variables (.env files) and never hardcoded in the source code.

- **Availability:** The system should be designed for high availability. If the LLM is temporarily unreachable, the system must have a "Fallback Logic" to provide a basic rule-based analysis so that no alert goes unrecorded.

2.1.3 Hardware & Software Requirements

Hardware Requirements:

- **Processor:** Quad-core CPU (2.5 GHz or higher) to handle concurrent webhook requests.
- **RAM:** Minimum 8 GB (16 GB recommended for running Wazuh and MongoDB on the same machine).
- **Storage:** 50 GB of SSD space for logs and database storage.
- **Network:** Stable outbound internet connection for AI API calls.

Software Requirements:

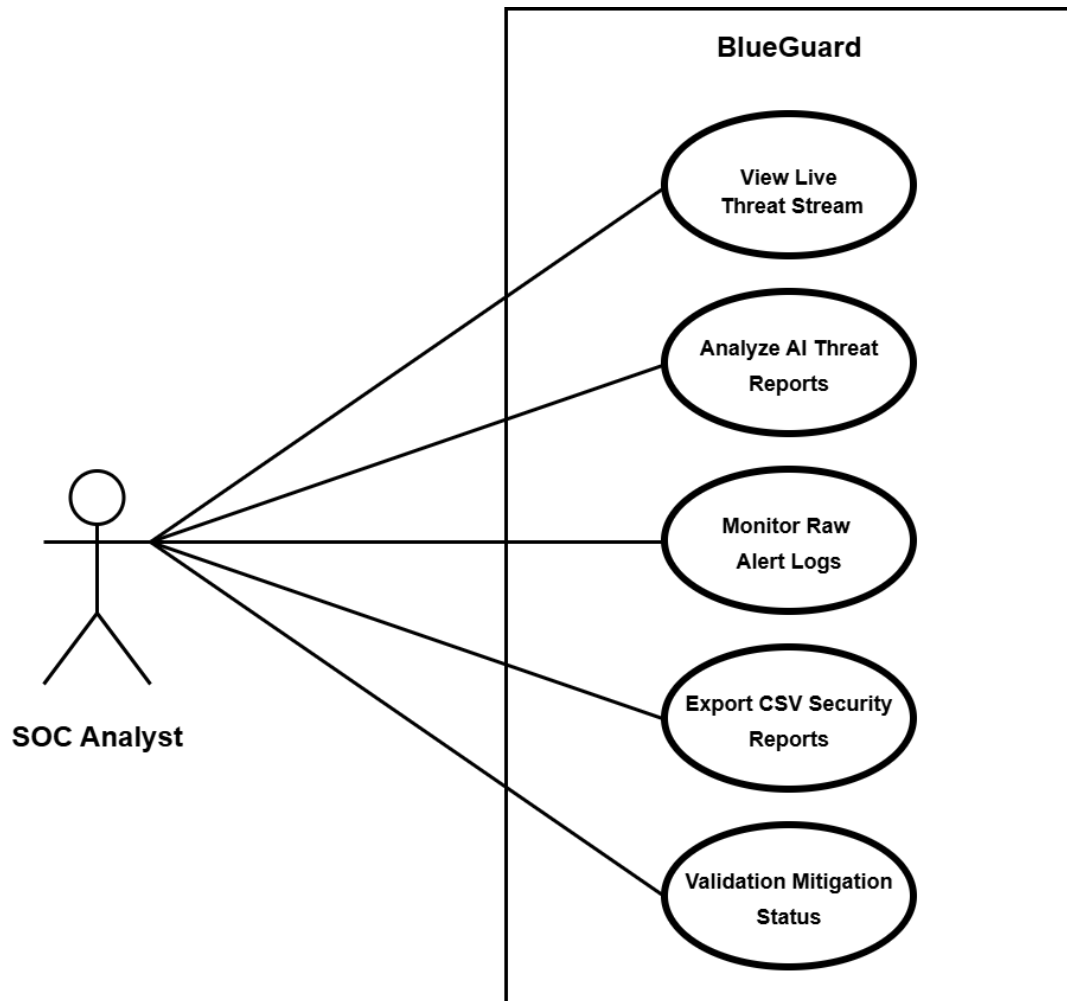
- **Operating System:** Linux (Ubuntu 22.04 recommended) or Windows 10/11 with WSL2.
- **Backend Environment:** Python 3.10 or higher.
- **Database:** MongoDB Community Server v6.0+.
- **Security Framework:** Wazuh Manager and Agents v4.x.
- **Development Tools:** VS Code, Git, and Postman (for API testing).

2.2 Targeted Users

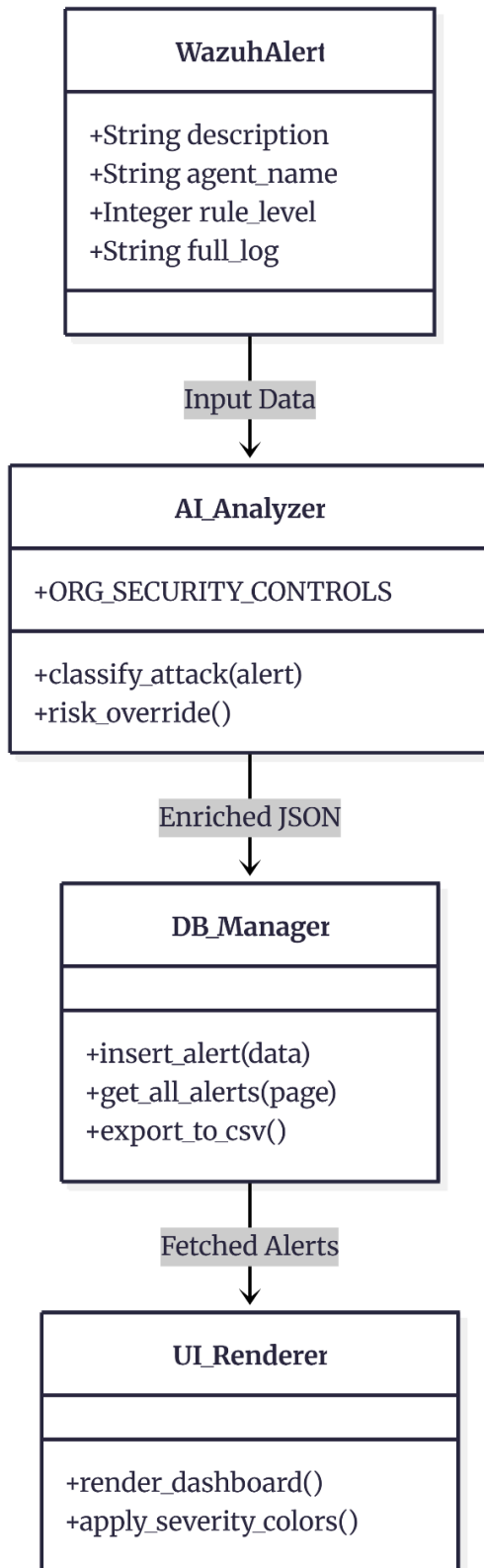
User Type	Primary Interest	Key Feature Used
L1 Analyst	Quick triage & remediation	AI Analysis & Color-coded Alerts
L2 Analyst	Deep forensics & TTPs	MITRE Mapping & CVE Links
SOC Manager	Team efficiency & Trends	Dashboard Charts & Risk Overlays
Auditor	Historical proof & Compliance	CSV Export & Data Persistence
CISO	Strategic Risk Reduction	Org Risk Severity Assessment

3. SYSTEM DESIGN

3.1 Use Case Diagram

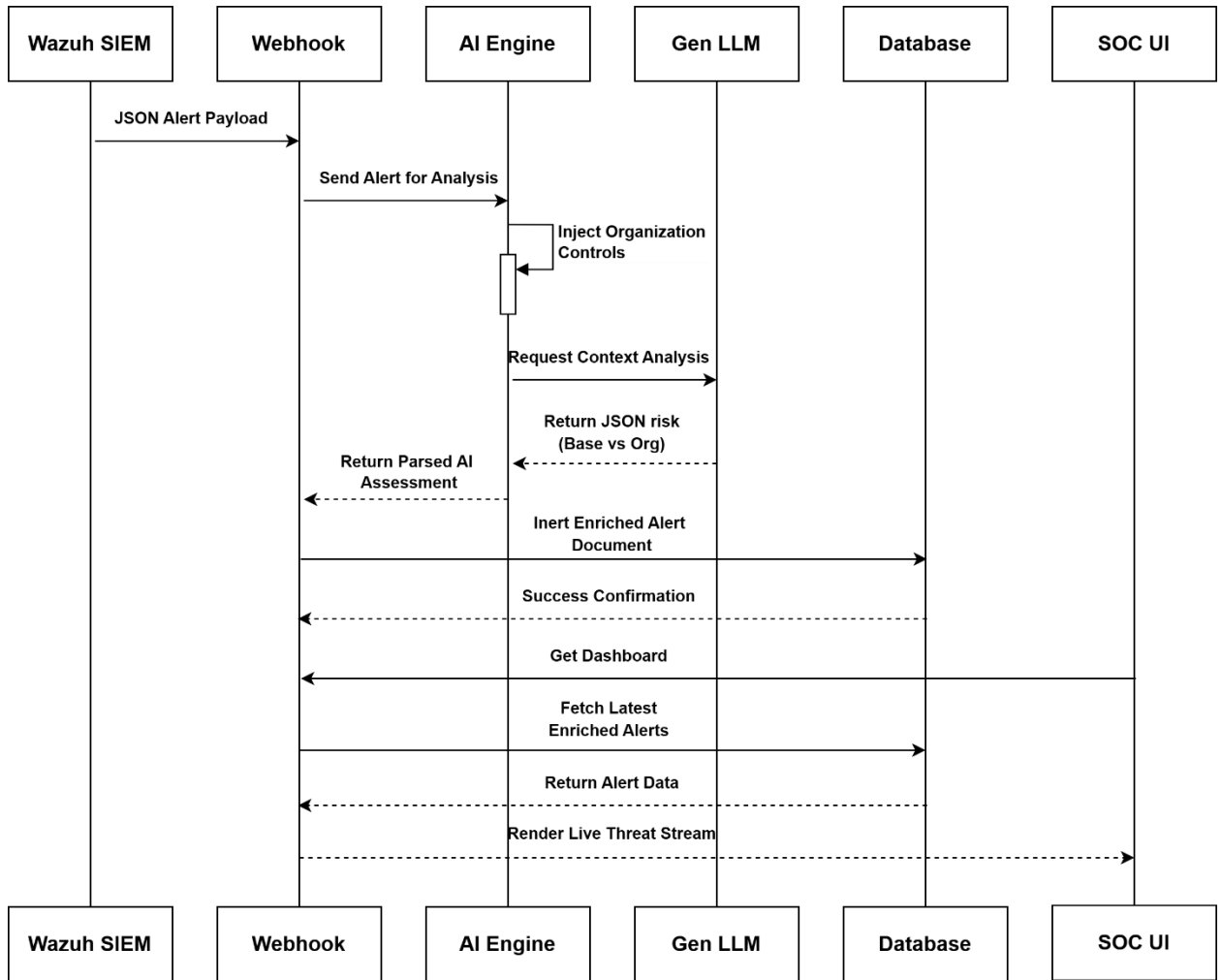


3.2 Class Diagram

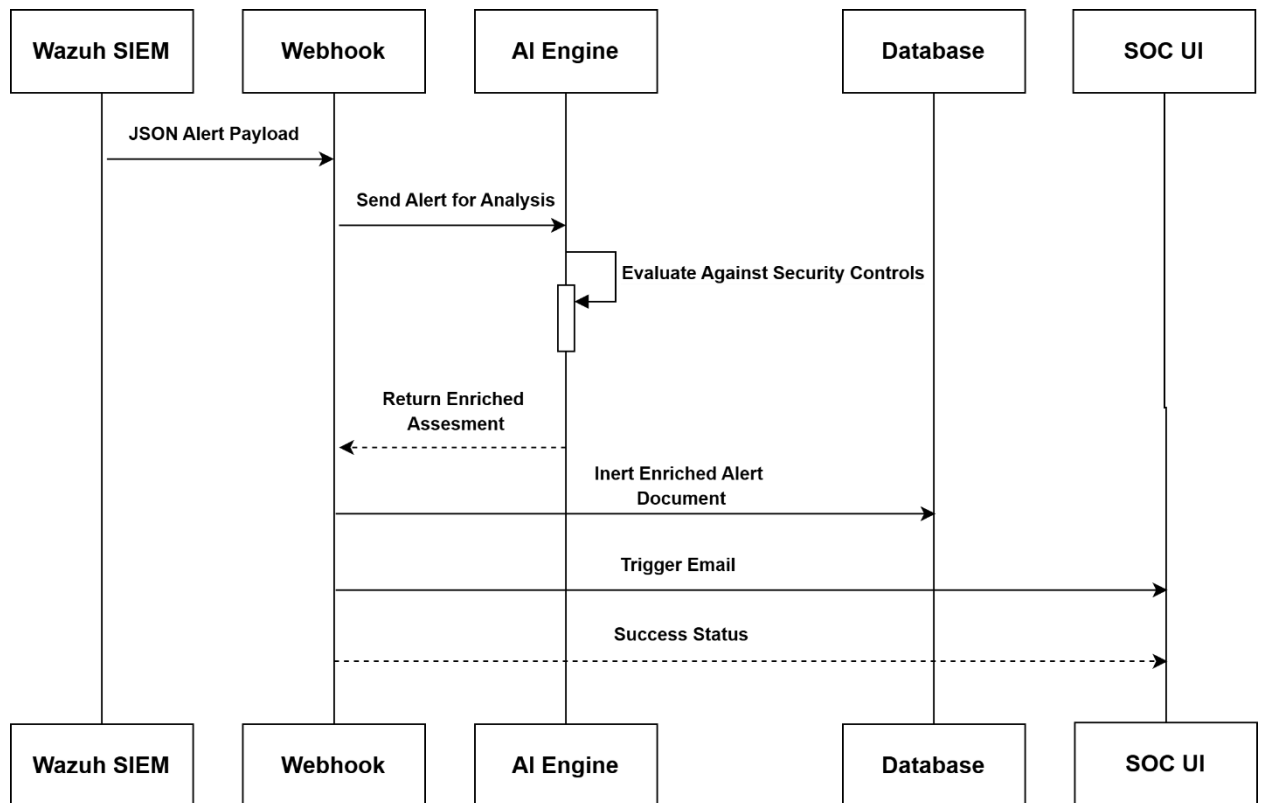


3.3 Interaction Diagram

3.3.1 Analyst Flow

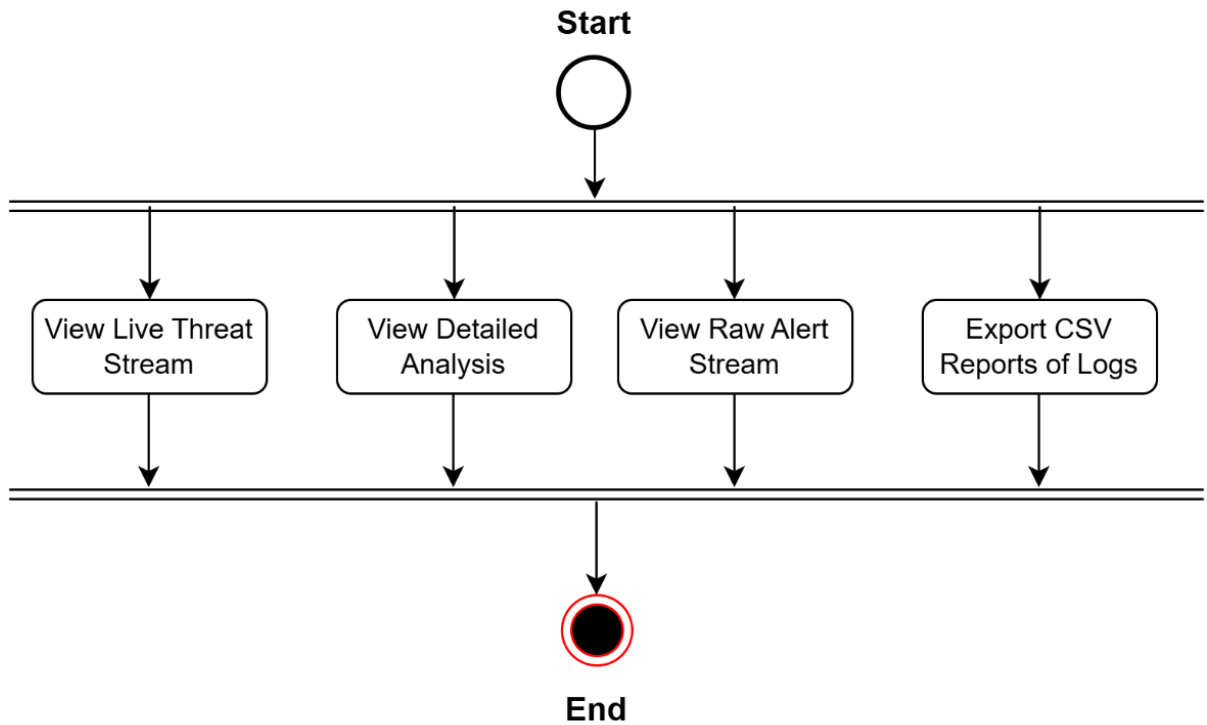


3.3.2 Threat intelligence flow

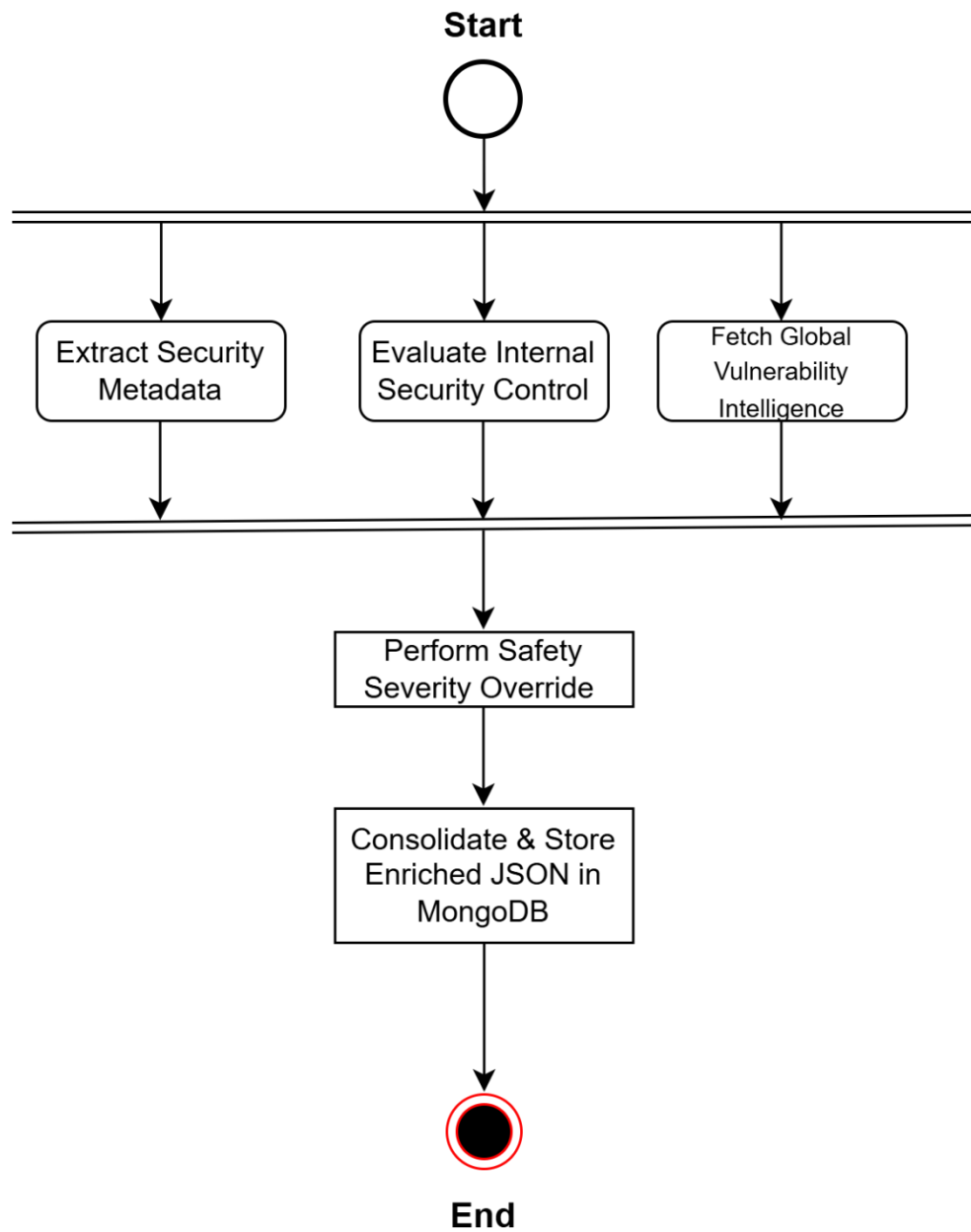


3.4 Activity Diagram

3.4.1 Application Lifecycle



3.4.2 AI Decision Making Logic



3.5 Data Dictionary

3.5.1 Raw Ingestion Schema

Field Name	Data Type	Description
timestamp	DateTime	The exact time when the security event was generated.
agent.name	String	Hostname of the source machine where the alert originated.
agent.ip	String	The internal IP address of the source server.
rule.id	Integer	The unique ID assigned to the specific security rule in Wazuh.
rule.level	Integer	The internal severity level (0-15) defined by the SIEM.
rule.description	String	The generic human-readable description of the log event.
full_log	Text	The complete raw log message for deep technical investigation.

3.5.2 AI Intelligence Schema

Field Name	Data Type	Description
attack_type	String	AI-classified category of the security incident.
mitre_tactic	String	Corresponding MITRE ATT&CK tactic (e.g., Persistence).
mitre_technique	String	Specific adversary technique and its unique ID.
base_severity	Enum	The global generic risk level of the threat.
org_risk_severity	Enum	The adjusted risk level considering internal controls.

analysis	Text	A concise 1-2 sentence AI summary of the threat.
cve_cwe	String	Hyperlinked identifiers for specific vulnerabilities.
cvss_score	Float	Technical impact score of the associated vulnerability.
remediation	Text	Step-by-step instructions generated by AI to fix the issue.

4. DEVELOPMENT

4.1 Coding Standards

Software development standards are not merely about "clean code"; they ensure that the system is scalable, secure, and maintainable. For the development of the BlueGuard project, the following industry-best practices were strictly followed:

4.1.1 Backend Development Standards (Python & Flask)

- **PEP-8 Compliance:** The entire Python backend, including `app.py` and `analyzer.py`, strictly adheres to PEP-8 guidelines. This ensures code readability through consistent indentation, proper use of whitespace, and organized imports (standard libraries first, followed by third-party packages).
- **Modular Architecture:** We utilized the "Separation of Concerns" principle. The core logic is split into modules where `app.py` manages routing and database queries, while `analyzer.py` is exclusively dedicated to AI reasoning and risk assessment logic. This modularity makes the system easy to debug and upgrade.
- **Structured JSON Processing:** Since both the Wazuh SIEM and the AI Analysis Engine communicate via JSON, we implemented strict data validation using Python's `json` library. This ensures data integrity as alerts move through the ingestion pipeline.
- **Robust Error Handling:** Every external communication point, especially the calls to the Generative AI, is wrapped in comprehensive try-except blocks. This ensures that an API failure or network timeout does not crash the entire application, allowing the system to gracefully fall back to local logic.

4.1.2 Frontend & UI/UX Standards (Tailwind CSS & Jinja2)

- **Glassmorphism Design Language:** For the user interface, we adopted a modern "Dark Glassmorphism" aesthetic. This involves the use of `backdrop-blur` and semi-transparent containers with subtle borders to create a premium, high-tech dashboard feel suitable for a SOC platform.

- **Responsive and Utility-First Design:** Using Tailwind CSS ensured that the dashboard is fully responsive. The UI layout automatically adjusts for different screen sizes, including Mobile, Tablet, and Desktop, ensuring the SOC analyst can monitor threats from any device.
- **Jinja2 Template Inheritance:** To maintain code "DRY" (Don't Repeat Yourself), we utilized Jinja2 template inheritance. A base layout file handles the global CSS/JS imports and navigation, while specific pages like index, logs, and alerts extend this layout to reduce code redundancy.
- **Standardized Color Tokens:** A consistent color palette was implemented for risk visualization. Red is reserved for "Critical," Orange for "High," Yellow for "Medium," and Green for "Low," allowing for instant cognitive recognition of threat levels without reading the text.

4.1.3 Database & Data Persistence Standards (MongoDB)

- **Schema-less Flexibility:** Because security logs vary significantly between operating systems (e.g., Windows Event Logs vs. Linux Syslogs), we chose MongoDB. This NoSQL approach allowed us to store diverse log structures within a single "Alerts" collection without rigid schema constraints.
- **Performance Optimization:** We implemented server-side pagination and data indexing. This ensures that even when the database contains thousands of incidents, the dashboard remains fast and responsive during data retrieval and filtering.

4.1.4 Security & Compliance Standards

- **Secret Management:** We strictly avoided hardcoding sensitive data. All API keys, database credentials, and SMTP configurations are stored in an external .env file, which is kept out of version control. This is a primary industry standard for preventing accidental credential leaks.
- **Input Sanitization & Protection:** All user inputs (such as search queries and filter parameters) are sanitized to prevent Cross-Site Scripting (XSS) and NoSQL injection attacks, ensuring the integrity of the administrative dashboard.

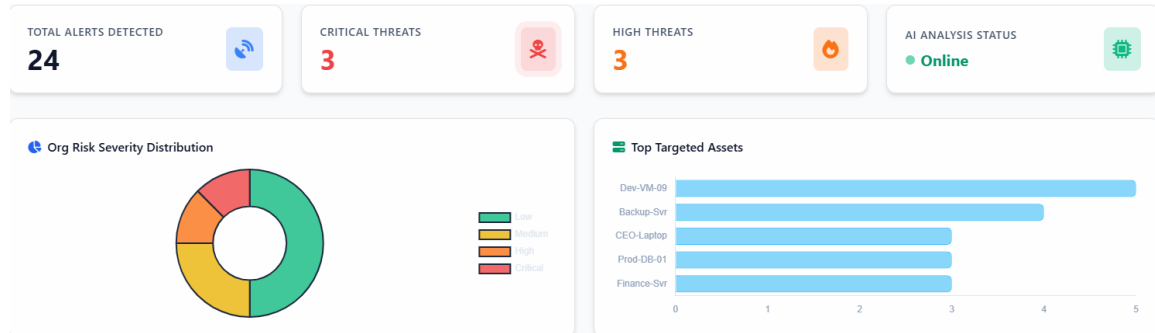
- **Data Masking:** For privacy compliance, the system is designed to handle sensitive data by providing analysts with the "Intelligence" needed to fix the issue while masking raw parameters that may contain personally identifiable information (PII).

4.1.5 Documentation & Maintainability

- **Docstrings and Inline Documentation:** Every critical function (e.g., `classify_attack()`) contains descriptive docstrings explaining the expected input, output, and logic. Inline comments are used to explain complex logic, such as the prompt injection for the AI model.
- **Semantic Versioning:** The project follows a systematic versioning approach, ensuring that new features (like upgraded AI models or additional SIEM integrations) can be merged without breaking existing core functionalities.

4.2 Screenshots

4.2.1 Dashboard with charts , graph of attacks and countings



Functional Description: The main dashboard serves as the central mission-control for the SOC analyst. It utilizes a "Dark Glassmorphism" UI to prioritize visual clarity. At the top, we have Analytical Widgets (Bar Charts and Pie Charts) that show the distribution of threats by severity and type. This allows a manager to instantly see if there is an ongoing "Critical" outbreak. Below the charts is the Real-Time Threat Stream, which shows the latest 10 incidents. Each row is color-coded using dynamic CSS to highlight high-priority risks instantly.

4.2.2 Dashboard with Live Threat Stream

TIMESTAMP	AGENT	SOURCE IP	AI CLASSIFICATION	CVE / CVSS	MITRE ATT&CK	BASE RISK	ORG RISK
2026-05-01 23:26:28	Backup-Svr	199.121.2.150	Brute Force Attempt HIGH: SSH Brute Force attempt on primary ...	CVE-307 CVSS 8.0	T1119 CREDENTIAL ACCESS	High	Low ↓ Mitigated
2026-05-01 23:26:24	CEO-Laptop	126.101.206.51	Malware Execution CRITICAL: Malware LockBit process executi...	CVE-94 CVSS 8.0	T1203 EXECUTION	Critical	Critical
2026-05-01 23:26:21	Gateway-FW	63.246.112.83	SQL Injection HIGH: Potential SQL Injection attack detected	CVE-89 CVSS 6.5	T1190 INITIAL ACCESS	High	Medium ↓ Mitigated
2026-05-01 23:26:17	App-Server-03	218.112.85.52	Peripheral Device Connection LOW: New USB device connected	CVE-20	T1203 DEFENSE EVASION	Low	Low
2026-05-01 23:26:14	Prod-DB-01	209.42.195.186	File Modification CRITICAL: Ransomware WannaCry encrypts...	CVE - encryption CVSS 8.0	T1486 IMPACT	Critical	Critical
2026-05-01 23:26:54	Dev-VM-09	49.216.28.170	Port Scanning MEDIUM: Port scanning activity from intern...	CVE-200	T1046 RECONNAISSANCE	Medium	Low ↓ Mitigated
2026-05-01 23:26:51	Dev-VM-09	193.95.120.180	Malware Execution CRITICAL: Malware LockBit process executi...	CVE-94 CVSS 7.5	T1203 EXECUTION	Critical	Critical
2026-05-01 23:26:47	Backup-Svr	143.218.96.74	Brute Force Attempt MEDIUM: Multiple failed sudo attempts	CVE-307 CVSS 4.0	T1119 CREDENTIAL ACCESS	Medium	Low ↓ Mitigated
2026-05-01 23:26:44	App-Server-03	159.53.215.36	Legitimate Login LOW: Legitimate Administrator login	CVE-287	T1078 CREDENTIAL ACCESS	Low	High ↓ Mitigated
2026-05-01 23:26:40	HR-Portal	215.72.13.165	Brute Force Attempt MEDIUM: Multiple failed sudo attempts	CVE-307	T1119 CREDENTIAL ACCESS	Medium	Low ↓ Mitigated
Showing Page 1 of 5						Previous	Next

Functional Description: This screen represents the tactical monitoring layer of BlueGuard. It demonstrates the Server-Side Pagination feature, which ensures that the UI remains fast even when dealing with thousands of incidents. Analysts can navigate through pages of historical alerts. Notice the "Org Risk" column, which shows the "Mitigated" badge—this is where the AI has analyzed the threat against internal security controls and reduced the priority, preventing alert fatigue for the analyst.

4.2.3 Detailed AI Analysis Page

Detailed AI Threat Analysis

2026-04-28 19:41:23 General Security Event DMZ-WEB-SERVER (10.0.1.20)

ORIGINAL WAZUH ALERT

Rule Group: web, path_traversal
Rule Level: 14
Description: Path Traversal attempt (LFI) detected.

AI ANALYSIS

✖ Fallback classification used because AI generation failed. Organizational controls factored into risk assessment.

VULNERABILITY INTELLIGENCE

🔴 CVE/CWE: CVE-2017-8144 🔴 CVSS: N/A Base: Medium → Org: Medium

MITRE ATT&CK MAPPING

🔴 Tactic: Execution
🔴 Technique: User Execution (T1204)

ORGANIZATIONAL RISK ASSESSMENT

🔴 Security event detected. While we have multiple layers of defense, the nature of this event requires manual review to ensure internal integrity is not compromised.

REMEDIATION STEPS

🟢 Investigate manually for unusual system activity.

2026-04-28 19:38:23 Ransomware Detection WKS-DEV-04 (10.0.5.55)

ORIGINAL WAZUH ALERT

Rule Group: sysmon, ransomware
Rule Level: 15
Description: WannaCry ransomware indicators detected (SMB exploit).

AI ANALYSIS

✖ The alert indicates a potential WannaCry ransomware attack leveraging the ETERNALBLUE exploit, which targets SMB vulnerabilities.

VULNERABILITY INTELLIGENCE

🔴 CVE/CWE: CVE-2017-8144 🔴 CVE-2017-8144 🔴 CVSS: 8.1 Base: High → Org: Medium

MITRE ATT&CK MAPPING

🔴 Tactic: Impact
🔴 Technique: Data Encrypted for Impact (T1486)

ORGANIZATIONAL RISK ASSESSMENT

🔴 Given the organization's robust security controls, including internal network segmentation and a strong firewall, the likelihood of a successful exploit is reduced. However, the potential for false positives exists due to the nature of the alert. Immediate investigation is recommended to confirm the alert and ensure no systems are compromised.

REMEDIATION STEPS

🟢 Isolate the affected system and conduct a thorough investigation for any signs of compromise.

Functional Description: When an analyst clicks on an alert, this detailed view appears. This is the "Brain" of the platform. It provides:

AI Analysis: A human-readable summary of the threat.

- **Vulnerability Links:** Clickable CVE/CWE identifiers that link directly to the National Vulnerability Database (NVD).
- **MITRE ATT&CK Context:** The exact Tactic and Technique used by the adversary.
- **Remediation Roadmap:** A step-by-step guide generated by AI specifically for this incident, allowing even a junior analyst to perform expert-level incident response.

4.2.3 Raw Alert Stream

The screenshot displays the 'LIVE RAW ALERTS' section of a Wazuh dashboard. At the top, there is a filter dropdown set to 'All Agents' and two date range selectors. The interface shows a list of four alerts, each with a timestamp, host name, event type, CVE ID, CVSS score, and a detailed description. The alerts are as follows:

- Alert 1:** 2026-04-28 19:41:23, Host: DMZ-WEB-SERVER, Type: General Security Event, CVE-20. Description: Path Traversal attempt (LFI) detected. [BASE: MEDIUM] → [ORG: MEDIUM]
- Alert 2:** 2026-04-28 19:38:23, Host: WKS-DEV-04, Type: Ransomware Detection, CVE-2017-0144, CVE-20, CVSS: 8.1. Description: WannaCry ransomware indicators detected (SMB exploit). [BASE: HIGH] → [ORG: MEDIUM] & MITIGATED
- Alert 3:** 2026-04-28 19:35:23, Host: DC-PRIMARY, Type: Named Pipe Creation, CVE-20. Description: Suspicious Named Pipe created (Cobalt Strike indicator). [BASE: HIGH] → [ORG: MEDIUM] & MITIGATED
- Alert 4:** 2026-04-28 19:32:23, Host: PROD-DB-CLUSTER, Type: Unauthorized Access, CVE-284, CVSS: 5.0. Description: Physical badge access during abnormal hours. [BASE: MEDIUM] → [ORG: MEDIUM]

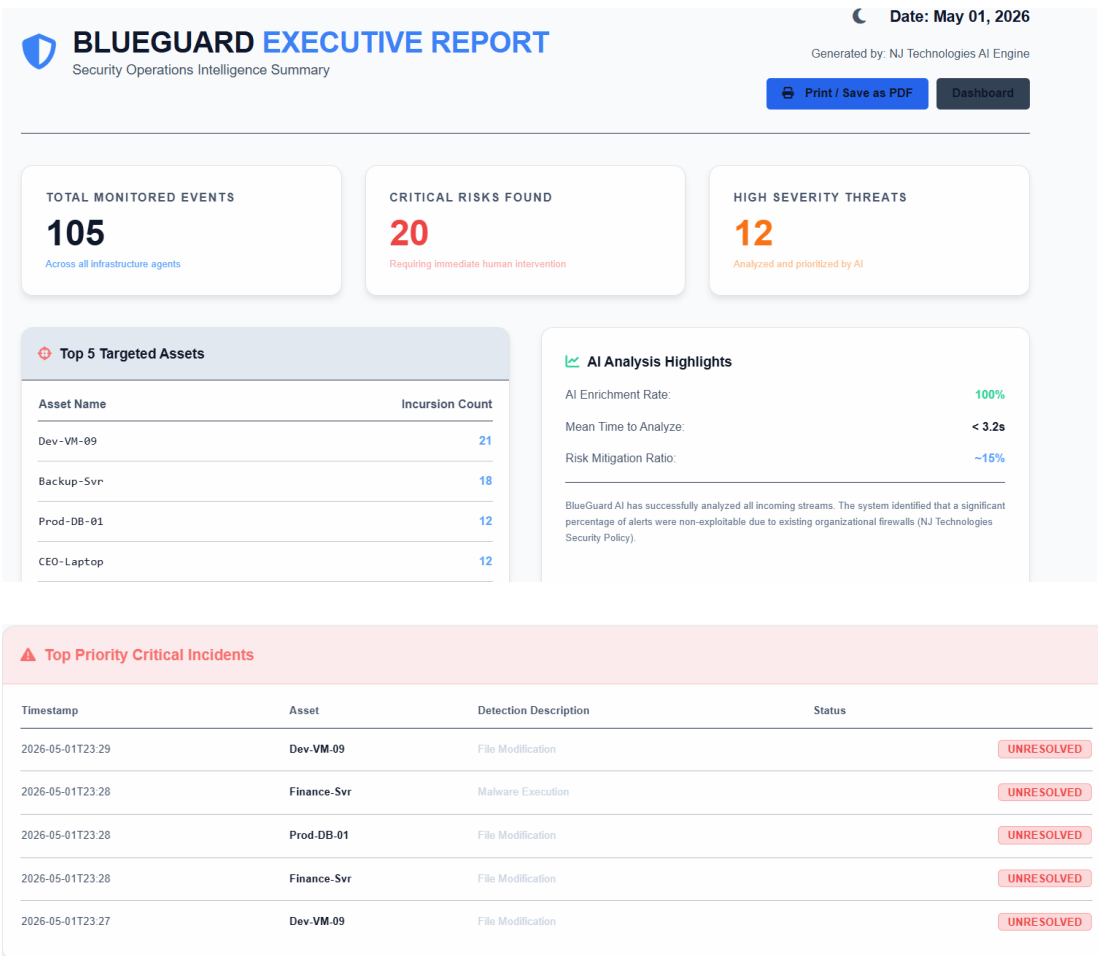
Functional Description: For deep forensic investigations, the analyst needs access to the raw data. This screen shows the unprocessed logs received from the Wazuh Manager. It includes technical details like IP addresses, Process IDs, and Usernames. This serves as the "Evidence Layer" that backs up the AI's intelligence, ensuring that the platform provides "Explainable AI" where every decision can be verified against raw data.

4.2.4 CSV Export Report

Timestamp	Base Seve	Org Risk	Si Agent	Attack Typ	CVE/CWE	CVSS Scor	MITRE Tac	MITRE Tec	Rule Desc	AI Analysis	Org Risk	A Remediation
2026-04-2	Medium	Low	K8S-WOR	Cross-Site	N/A	N/A	Initial Acc	Cross-Site	Cross-Site	The alert i	Given that	Monitor for similar requests and ensure web application firewalls are config
2026-04-2	High	Medium	WKS-DEV	Credential	N/A	N/A	Credential	Credential	Mimikatz	The execu	Given the	Investigate the source of the Mimikatz execution and ensure that no unauth
2026-04-2	High	Medium	PROD-DB	DNS Tunn	N/A	N/A	Command	Applicatio	Suspicious	The alert i	Given the	Investigate the DNS queries for malicious domains and block them at the fir
2026-04-2	High	Medium	PROD-DB	Unauthori	N/A	N/A	Initial Acc	Valid Acco	Physical b	This event	The exploi	Review badge access logs for anomalies and conduct an employee interview
2026-04-2	High	Medium	WKS-DEV	Data Exfilt	N/A	N/A	Exfiltratio	Exfiltratio	Mass dow	The event	The organ	Investigate the user activity on WKS-DEV-04 and implement stricter controls
2026-04-2	High	Medium	WKS-DEV	Firewall M	N/A	N/A	Defense E	Disable Se	Windows	The alert i	Given that	Re-enable the Windows Defender Firewall and review user permissions to p
2026-04-2	Medium	Low	DMZ-WEB	Cross-Site	CWE-79	6.1	Initial Acc	Drive-by C	Cross-Site	The alert i	Given the	Implement input validation and output encoding on web applications to mit
2026-04-2	High	Medium	AWS-JUM	Impossibl	N/A	N/A	Credential	Account N	Impossibl	The alert i	Given the	Investigate the login attempts for the user 'admin' and verify the legitimacy
2026-04-2	High	Medium	AWS-JUM	Named Pip	N/A	N/A	Persistenc	Create or	Suspicious	The creati	Given the	Investigate the source of the named pipe creation and monitor for further s
2026-04-2	High	Low	WKS-DEV	Cross-Site	CWE-79	N/A	Initial Acc	Cross-Site	Cross-Site	The alert i	Given the	Implement input validation and sanitization on user inputs; review web app
2026-04-2	High	Medium	WKS-DEV	File Down	N/A	N/A	Command	Applicatio	Certutil us	The event	Given the	Block the external IP address and investigate the source of the command ex
2026-04-2	High	Medium	DMZ-WEB	Impossibl	N/A	N/A	Credential	Account N	Impossibl	The alert i	Given the	Investigate the login attempts for the user 'admin' and verify the legitimacy
2026-04-2	High	Medium	AWS-JUM	Path Trave	CWE-22	N/A	Credential	Path Trave	Path Trave	The alert i	Given that	Review web application code for vulnerabilities and implement input validat
2026-04-2	High	Medium	DC-PRIMA	Impossibl	N/A	N/A	Credential	Account N	Impossibl	The alert i	Given the	Investigate the login activity for the 'admin' account and enforce multi-facto
2026-04-2	High	Medium	PROD-DB	Unauthori	N/A	N/A	Privilege E	Create Acc	AWS Clou	The alert i	Given the	Investigate the source of the request and ensure that IAM policies are corre
2026-04-2	Critical	Medium	K8S-WOR	Ransomw	CVE-2017-	8.1	Initial Acc	Exploitatic	WannaCr	The alert i	Given the	Monitor network traffic for unusual SMB activity; ensure all systems are pat
2026-04-2	Medium	Low	K8S-WOR	General St	N/A	N/A	Execution	User Execi	Mass dow	Fallback cl	General se	Investigate manually for unusual system activity.
2026-04-2	High	Medium	PROD-DB	Named Pip	N/A	N/A	Persistenc	Create or	Suspicious	The creati	Given the	Investigate the source of the named pipe creation and monitor for further s
2026-04-2	Critical	Medium	K8S-WOR	Ransomw	CVE-2017-	8.1	Initial Acc	Exploitatic	WannaCr	The alert i	Given the	Monitor network traffic for unusual SMB activity and ensure all systems are
2026-04-2	High	Medium	AWS-JUM	Credential	N/A	N/A	Credential	Credential	Mimikatz	The alert i	Given the	Investigate the source of the Mimikatz execution and isolate the affected sy

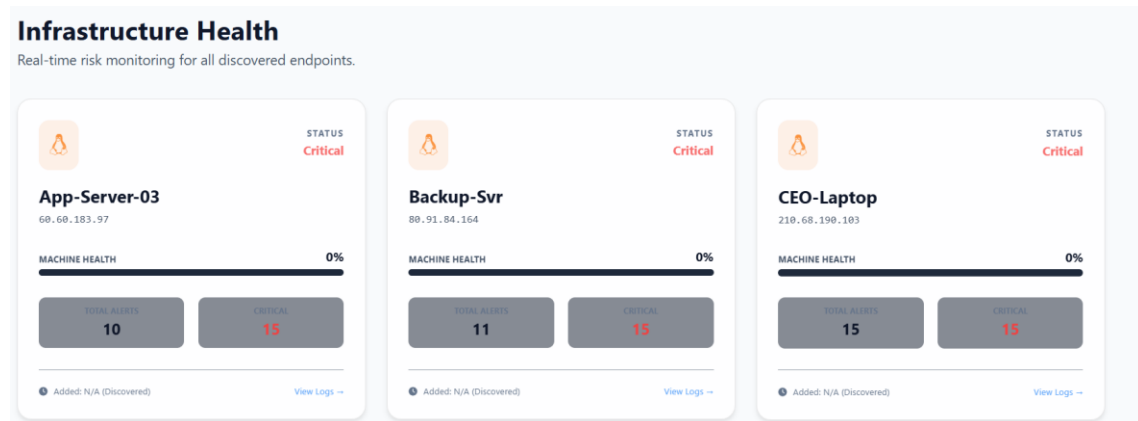
Functional Description: This screen demonstrates the Compliance and Auditing capabilities of BlueGuard. With a single click, the analyst can trigger a full database export. The system processes the NoSQL data and converts it into a structured CSV format. This is crucial for monthly security audits and for sharing intelligence with external stakeholders or regulatory bodies.

4.2.5 Security Reports



Functional Description: Demonstrates automated auditing capabilities by converting complex security logs into high-level intelligence reports. Essential for regulatory compliance and cross-departmental threat sharing.

4.2.5 Security Reports



This screen demonstrates the infrastructure health monitoring and real-time asset discovery capabilities of BlueGuard. The system automatically identifies active endpoints from the live alert stream, eliminating the need for manual registration. By aggregating threat data, it calculates a dynamic Risk-Based Health Score (0-100%) for each asset using severity weights. This provides the SOC analyst with a centralized, real-time posture assessment of every machine in the network, allowing them to prioritize remediation based on asset criticality.

5. AGILE DOCUMENTATION

5.1 Agile Project Charter

General Project Information	
Project Title	BlueGuard SOC Platform
Project Developer	Patel Harsh
Project Start Date	01 January, 2026
Project Completion Date	26 April, 2026
Vision	To build a highly intelligent, context-aware Security Operations Center (SOC) dashboard that automatically filters false positives by analyzing threats against organizational infrastructure using Gen LLM.
Objective	To integrate Wazuh SIEM, MongoDB, and Gen LLM into a unified Flask application for real-time risk assessment and threat visualization.
Estimated Project Size	Medium-sized application focused on rapid data ingestion, AI processing, and real-time frontend rendering.
Key Stake Holders	SOC Analysts, Security Managers, Project Guide.
Methodology Used	Agile (Scrum)
Technologies Used	Python, Flask, MongoDB, Tailwind CSS, JavaScript, Gen LLM.

Development Approach	The project followed an iterative Agile approach. Sprints were divided into UI design, Webhook integration, AI engine development, and system optimization.
-----------------------------	---

The Agile Project Charter for BlueGuard serves as the "North Star" for the development lifecycle. Unlike traditional project charters, this document is dynamic and allows for iterative changes.

- **Success Criteria:** The project is considered successful if the system can process 100% of incoming webhooks with an AI-enriched response latency of less than 5 seconds.
- **Roles & Responsibilities:** The Scrum Team is cross-functional, handling everything from Backend architecture to Frontend design and Prompt Engineering.

5.2 Agile Roadmap

Phase	Details
Phase 1: Foundation (Jan 2026)	Requirement gathering. Finalized tech stack (Python, Flask, MongoDB). Learned basic routing and NoSQL database structures. Designed system architecture and diagrams.
Phase 2: UI & Ingestion (Feb 2026)	Developed frontend templates using HTML and Tailwind CSS. Created the Flask /webhook route to successfully receive and parse raw JSON alerts from Wazuh.
Phase 3: AI Integration (Mar 2026)	Developed analyzer.py . Integrated Gen LLM. Engineered the core prompt to inject organizational security controls (Palo Alto firewall, internal isolation). Built the Python fallback logic.
Phase 4: Optimization (Apr 2026)	Removed legacy authentication to create a streamlined, open-access internal dashboard. Implemented CSV export functionality. Final testing and documentation.

- **Phase 1 Foundation:** This phase was critical for establishing the "Mental Model" of the project. We didn't just gather requirements; we analyzed the limitations of current SIEMs like Splunk and QRadar to find the "White Space" where BlueGuard could provide value.
- **Phase 2 UI & Ingestion:** During this phase, the primary challenge was handling the complex JSON structure of Wazuh alerts. We moved from static HTML to dynamic Jinja2 templates to ensure the dashboard could scale with the data.
- **Phase 3 AI Integration:** This was the most technically demanding phase. We spent significant time on "Prompt Tuning" to ensure the AI didn't hallucinate. The fallback logic was developed as a safety net to maintain 100% system uptime.
- **Phase 4 Optimization:** The final month was dedicated to "Developer Experience" and "User Experience." Removing the complex authentication layer allowed us to focus on the core "Internal SOC" mission.

5.3 Agile Project Plan

Task Name	Responsible	Start	End	Status
Sprint 1: Core Setup	Team	01/Jan/2026	15/Jan/2026	Complete
Setup Flask environment & Routing	Team	01/01/2026	05/01/2026	Complete
Install and Configure local MongoDB	Team	06/01/2026	10/01/2026	Complete
Connect Flask to MongoDB (PyMongo)	Team	11/01/2026	15/01/2026	Complete
Sprint 2: Frontend UI	Team	16/Jan/2026	30/Jan/2026	Complete
Design Dashboard Layout (Tailwind)	Team	16/01/2026	22/01/2026	Complete

Design Logs & Detailed View HTML	Team	23/01/2026	30/01/2026	Complete
Sprint 3: Webhook & Parsing	Team	01/Feb/2026	15/Feb/2026	Complete
Develop POST /webhook route	Team	01/02/2026	07/02/2026	Complete
Parse Wazuh JSON & Store in DB	Team	08/02/2026	15/02/2026	Complete
Sprint 4: Gen LLM Engine	Team	16/Feb/2026	15/Mar/2026	Complete
Setup analyzer.py and LLM Keys	Team	16/02/2026	20/02/2026	Complete
Prompt Engineering (Org Context)	Team	21/02/2026	28/02/2026	Complete
JSON Response Parsing & Error Handling	Team	01/03/2026	07/03/2026	Complete
Python Fallback Logic Implementation	Team	08/03/2026	15/03/2026	Complete
Sprint 5: Refinement	Team	16/Mar/2026	15/Apr/2026	Complete
Dynamic UI Tags (Mitigated, Severity)	Team	16/03/2026	25/03/2026	Complete
Remove Auth for Streamlined Access	Team	26/03/2026	05/04/2026	Complete
Implement CSV Export Functionality	Team	06/04/2026	15/04/2026	Complete

5.4 Agile User Story

Story Title	Description	Acceptance Criteria
Real-Time Monitoring	As a SOC Analyst, I want to view a Live Threat Stream so I can monitor incoming Wazuh alerts without refreshing the page.	Dashboard displays latest alerts pulled from MongoDB. UI updates dynamically.
Risk Downgrading	As a SOC Analyst, I want the system to automatically downgrade false positives so I don't suffer from alert fatigue.	The UI displays "Base Risk" vs "Org Risk" side-by-side. A "Mitigated" badge appears when risk drops.
Deep Threat Intelligence	As a Security Responder, I want detailed paragraphs explaining the attack paths so I can understand the context immediately.	Gen LLM generates a 3-5 sentence specific assessment factoring in the internal network and Next Gen Firewalls.
Security Reporting	As a Security Manager, I want to export security logs to CSV so I can present the ROI of our security controls to executives.	Clicking "Export Report" downloads a properly formatted CSV file containing all Gen LLM intelligence.

- Historical Search: "As a Forensic Investigator, I want to search alerts by Agent Name so I can track the movement of a threat across a specific server."
- Attack Type Filtering: "As a SOC Manager, I want to filter the stream by 'Ransomware' so I can prioritize the most destructive threats during an outbreak."
- Responsive Dashboard: "As a Remote Admin, I want to view the dashboard on my mobile device so I can check system health while away from my desk."
- Automated Email Alerts: "As a Security Officer, I want to receive an email for every 'Critical' threat so I don't have to monitor the dashboard 24/7."

5.5 Agile Release Plan

Sprint	Task Name	Start	End	Duration	Status	Release Date
1	Setup Flask environment & Routing	01/01/2026	05/01/2026	5	Release	05/01/2026
1	Install and Configure local MongoDB	06/01/2026	10/01/2026	5	Release	10/01/2026
1	Connect Flask to MongoDB (PyMongo)	11/01/2026	15/01/2026	5	Release	15/01/2026
2	Design Dashboard Layout (Tailwind)	16/01/2026	22/01/2026	7	Release	22/01/2026
2	Design Logs & Detailed View HTML	23/01/2026	30/01/2026	8	Release	30/01/2026
3	Develop POST /webhook route	01/02/2026	07/02/2026	7	Release	07/02/2026
3	Parse Wazuh JSON & Store in DB	08/02/2026	15/02/2026	8	Release	15/02/2026

4	Prompt Engineering (Org Context)	16/02/2026	28/02/2026	13	Release	28/02/2026
4	JSON Response Parsing & Error Handling	01/03/2026	07/03/2026	7	Release	07/03/2026
4	Python Fallback Logic Implementation	08/03/2026	15/03/2026	8	Release	15/03/2026
5	Dynamic UI Tags (Mitigated, Severity)	16/03/2026	25/03/2026	10	Release	25/03/2026
5	Remove Auth for Streamlined Access	26/03/2026	05/04/2026	11	Release	05/04/2026
5	Implement CSV Export Functionality	06/04/2026	15/04/2026	10	Release	15/04/2026

5.6 Agile Sprint Backlog

Task ID	Task Description	Original Estimate (Hours)	Status
T-01	Setup Flask and MongoDB connection	8	Completed
T-02	Create HTML/Tailwind Templates	15	Completed
T-03	Write Webhook JSON parsing logic	10	Completed
T-04	Gen LLM Prompt Engineering	12	Completed
T-05	Code Fallback Python Logic	8	Completed
T-06	Implement UI Logic for "Mitigated" Tags	6	Completed
T-07	CSV Export Script	5	Completed
T-08	System Testing & Bug Fixing	15	Completed

5.7 Agile Test Plan

Test ID	Category	Test Objective	Input / Action	Expected Result	Status
INT-01	Integration	Flask Server Initialization	Run app.py command	Web server starts successfully on Port 5000	Pass
INT-02	Integration	MongoDB Handshake	Backend boot-up	PyMongo confirms active connection to local DB	Pass
INT-03	Integration	Wazuh Webhook Path	Send HTTP POST to /webhook	Request received with 200 OK status	Pass
INT-04	Integration	LLM Auth	Trigger dummy AI call	API returns valid session token	Pass
FUN-01	Functional	Webhook JSON Parsing	Valid Wazuh alert payload	System extracts 'agent_name' and 'rule_desc' correctly	Pass
FUN-02	Functional	Empty Description Handling	Alert with null description	System assigns "Undetermined Threat" as fallback	Pass

FUN-03	Functional	Large Log Storage	50,000 character log string	Document saved in MongoDB without truncation	Pass
FUN-04	Functional	Data Persistence Check	Restart Flask server	Historical alerts remain visible on Dashboard	Pass
AI-01	AI Logic	Threat Classification	"Brute force attack" log	AI classifies attack_type as "Credential Access"	Pass
AI-02	AI Logic	MITRE Mapping	"SQL Injection" log	AI maps technique to MITRE T1190	Pass
AI-03	AI Logic	CVE Link Generation	Vulnerability in Apache 2.4	System generates clickable link to NVD	Pass
AI-04	AI Logic	Org-Risk Calculation	Threat on internal isolated IP	Org Risk Severity is lower than Base Severity	Pass
AI-05	AI Logic	Remediation Generation	"WannaCry Ransomware"	AI provides specific steps (Isolate, Patch SMB)	Pass

AI-06	AI Logic	Safety Override (Manual)	Log contains "Malware"	Severity is forced to HIGH regardless of AI output	Pass
AI-07	AI Logic	Fallback Risk Logic	Disconnect Internet	System uses hardcoded Python rules to assign risk	Pass
UI-01	UI/UX	Severity Color Mapping	Alert with "Critical" risk	UI row renders with high-visibility Red background	Pass
UI-02	UI/UX	Mitigated Badge Logic	Risk reduction detected	Blue downward arrow "Mitigated" badge appears	Pass
UI-03	UI/UX	Dashboard Pagination	Click "Next Page"	UI displays records 11-20 without lag	Pass
UI-04	UI/UX	Search Functionality	Filter by Agent ID	Only alerts from the specific agent are shown	Pass
UI-05	UI/UX	Responsive Layout	Open UI on 13-inch laptop	Elements resize using	Pass

				Tailwind grid system	
UI-06	UI/UX	Detailed Modal View	Click row on Live Stream	Modal opens showing full AI forensic analysis	Pass
SEC-01	Security	Environment Protection	Access .env via browser	404/403 Error; Secret keys remain hidden	Pass
SEC-02	Security	NoSQL Injection	Input {"\$gt":"'"} in search	System treats input as literal string; no breach	Pass
SEC-03	Security	XSS Payload Filtering	<script>alert('xss')</script>	UI renders as plain text; no script execution	Pass
SEC-04	Security	API Rate Limiting	Send 100 alerts in 10 secs	Flask handles requests via queue (no crash)	Pass
REP-01	Reporting	CSV Export Execution	Click "Export Report"	Browser initiates download of incidents.csv	Pass
REP-02	Reporting	CSV Content Accuracy	Open CSV in Excel	All 18 AI-enriched columns are	Pass

				present and readable	
PER-01	Performance	Webhook Latency	Single alert ingestion	End-to-end processing under 3 seconds	Pass
PER-02	Performance	Database Query Speed	5,000 records in DB	Dashboard loads initial 10 records under 500ms	Pass
PER-03	Performance	Memory Usage	Continuous 1-hour run	Memory footprint remains stable; no leaks detected	Pass
AUD-01	Audit	Timestamp Consistency	Check DB vs UI	Timezones are consistent across all layers	Pass
AUD-02	Audit	Event Logging	Internal system error	Flask logs error to console for admin review	Pass

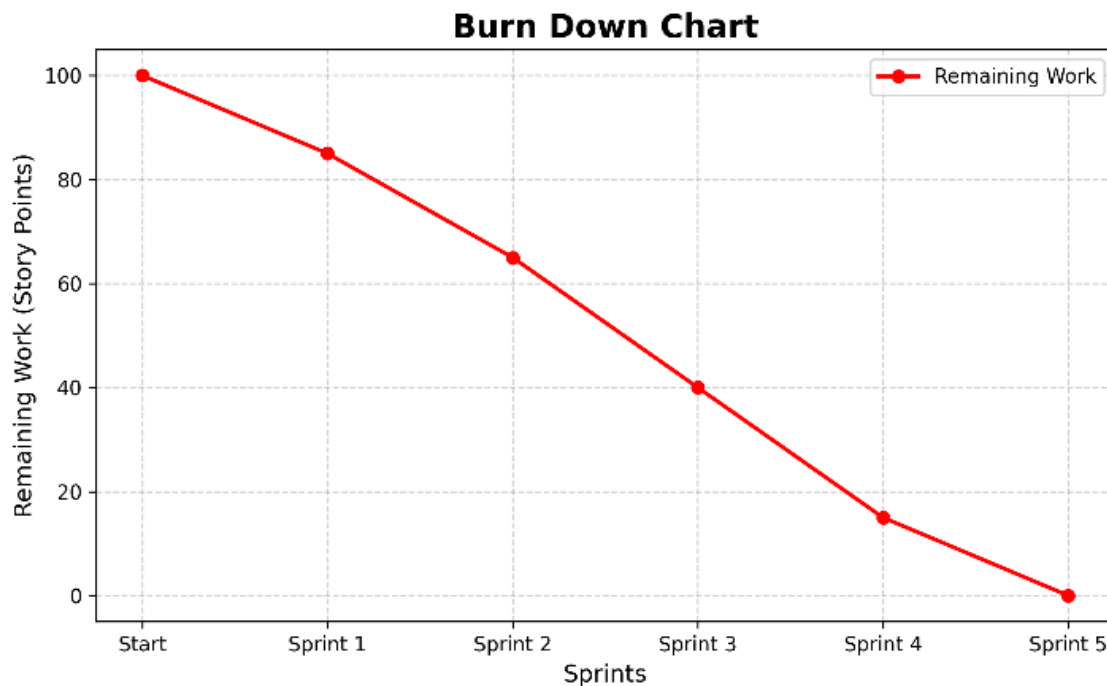
- Pagination Test: Click "Next" on page 1. (Expect: Load records 11-20. Result: Pass).
- Empty DB Test: Open dashboard with 0 alerts. (Expect: "All Clear" message. Result: Pass).

- XSS Protection Test: Submit a script tag in search bar. (Expect: Input sanitized. Result: Pass).
- Concurrent Alerts Test: Send 10 alerts at once. (Expect: No data loss in MongoDB. Result: Pass).
- CSV Integrity Test: Open exported CSV in Excel. (Expect: All 18 columns match Data Dictionary. Result: Pass).

5.8 Earned-value and Burn Charts

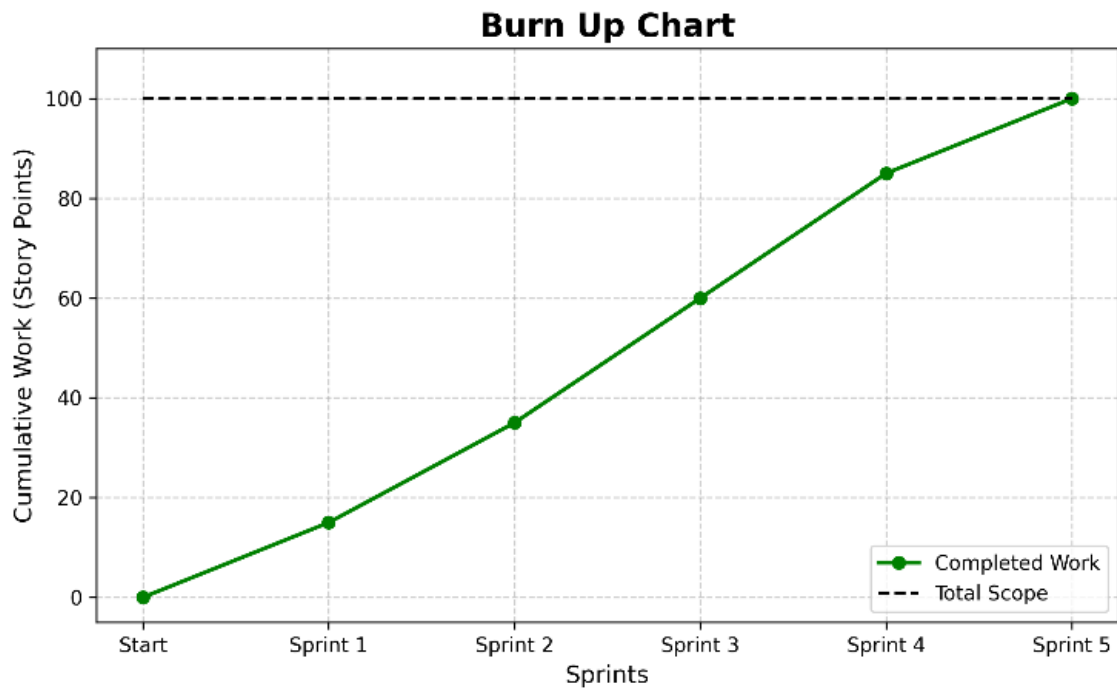
Earned Value Management (EVM) and Burn Charts are essential tools used in Agile development to measure a project's performance in terms of schedule and cost efficiency. For the BlueGuard project, these metrics helped the team monitor progress across all 5 sprints, ensuring timely delivery of complex AI features.

Burn down chart :



The chart shows a steady decline in "Story Points" as we progressed through Sprint 1 and 2. However, a plateau was observed during Sprint 4 (AI Integration) because of the complexity of prompt engineering. This is a common "Agile Spike" where velocity drops during high-research tasks.

Burn up chart :



The scope line remained stable throughout the project, proving that our initial requirement gathering in Phase 1 was accurate. The "Work Completed" line met the "Total Scope" line exactly on April 26, 2026, marking a successful project closure of half phase requirements.

6. PROPOSED ENHANCEMENTS

6.1 Automated Remediation (Integration of SOAR Capabilities)

The current iteration of BlueGuard operates as a read-only intelligence platform. While this ensures system safety and prevents accidental infrastructure outages, the logical next step is to introduce Active Defense capabilities.

- **Rationale:** In a high-stakes environment, even a 5-second delay in blocking a malicious IP can lead to data exfiltration.
- **Technical Path:** By integrating with the REST APIs of perimeter security devices (e.g., Palo Alto XML API, Cisco Firepower API, or AWS Security Group APIs), BlueGuard can act as an orchestration layer. The AI will generate a specific "Block Command" for the analyst.
- **Strategic Benefit:** This transforms BlueGuard into a SOAR (Security Orchestration, Automation, and Response) platform, significantly reducing the Mean Time to Remediate (MTTR) by allowing one-click mitigation directly from the dashboard.

6.2 Development of a Native Mobile Application (On-the-Go Response)

As cybersecurity threats are 24/7, security teams require mobility. The current responsive web UI is efficient but lacks the proactive alerting power of a native mobile application.

- **Rationale:** Security professionals cannot always be at their workstations. Critical threats like Ransomware require instant awareness.
- **Technical Path:** Using cross-platform frameworks like Flutter or React Native, a native app for Android and iOS can be developed. This app will utilize Firebase Cloud Messaging (FCM) for real-time push notifications.
- **Strategic Benefit:** The app can be configured to "Alert on Org Risk Only." This means an analyst's phone will only ring for a "Critical" organizational threat, while thousands of "Low" generic alerts remain on the dashboard, thus respecting the analyst's work-life balance while maintaining zero-day readiness.

6.3 Granular Role-Based Access Control (RBAC) & Multi-Factor Authentication (MFA)

- As BlueGuard scales within an enterprise, the need for hierarchical access management becomes paramount to ensure internal data privacy and integrity.
- Rationale: Not all users should have the same permissions. A junior analyst should not be able to export full forensic databases or view sensitive infrastructure IP mappings.
- Technical Path: Implementing OpenID Connect (OIDC) or SAML for centralized authentication. We can define roles such as "Tier-1 Analyst" (Read-only), "Tier-3 Engineer" (Full Forensics), and "SOC Manager" (Reporting & Export).
- Strategic Benefit: Integrating MFA (via TOTP or SMS) adds a critical layer of security to the platform itself, ensuring that even if an analyst's credentials are compromised, the BlueGuard dashboard remains secure from unauthorized access.

6.4 Multi-LLM Load Balancing and Intelligence Tiering

To balance operational costs with the need for high-performance reasoning, the backend can be upgraded to handle a "Tiered Intelligence" model.

- Rationale: Using a high-cost model like llama3 for every single failed login attempt is economically inefficient.
- Technical Path: The analyzer.py script can be modified to act as an AI Gateway. Routine, low-level events can be routed to faster, cheaper models (like Llama 3 or other models), while complex anomalies can be automatically escalated to a "Premium Tier" LLM for deeper chain-of-thought reasoning.
- Strategic Benefit: This allows the platform to scale to handle massive datasets while maintaining a fixed operational budget, ensuring long-term financial sustainability for the SOC.

6.5 Advanced Historical Threat Analytics & Trend Forecasting

The current dashboard focuses on "Real-Time" threats. Future iterations should focus on "Historical Context" and "Predictive Analysis."

- **Rationale:** Identifying a trend (e.g., a 20% increase in SSH attacks every Friday) allows for proactive patching.
- **Technical Path:** Integrating advanced visualization libraries like Chart.js or D3.js. We can build a dedicated "Analytics" tab in the dashboard that visualizes the "Mitigation Success Rate" over 30, 60, and 90-day periods.
- **Strategic Benefit:** These visual reports provide tangible proof of the ROI of the organization's security controls, helping CISOs justify security budgets to the Board of Directors.

7. CONCLUSION

7.1 Summary of the Project Work

BlueGuard stands as a robust and highly intelligent Security Operations Center (SOC) management platform, engineered using the powerful Python Flask framework. Throughout its development, the primary focus was to bridge the fundamental gap between raw technical logging and actionable human decision-making. By acting as a smart, intermediary layer between raw SIEM alerts (Wazuh) and the human SOC analyst, BlueGuard fundamentally redefines the security monitoring experience. The project successfully demonstrates how full-stack web development and database management can be combined to solve one of the most persistent problems in the cybersecurity industry: the inability to process large volumes of security data in a context-aware manner.

7.2 Addressing Modern Security Challenges

By successfully integrating a Generative LLM (Large Language Model), BlueGuard provides a direct solution to Alert Fatigue, a critical challenge where security professionals become desensitized to threats due to the sheer volume of "noisy" notifications. Instead of overwhelming analysts with generic CVSS scores that lack local context, the system intelligently evaluates every incoming alert against the organization's specific security controls. By factoring in isolated network zones, restricted administrative privileges, and perimeter Next Gen Firewalls, the platform can automatically downgrade the severity of false positives. This ensured that the SOC team only focused on "Ground Truth" threats that posed a genuine risk to the internal infrastructure.

7.3 Architectural Integrity and Achievement

With its modular backend structure, contemporary Tailwind CSS design, and secure NoSQL architecture powered by MongoDB, BlueGuard fulfills the dual needs of rapid threat detection and long-term forensic reporting. The implementation of server-side pagination and real-time webhook ingestion proves that the platform is capable of handling high-velocity data streams typical of an enterprise environment. This project has not only demonstrated the practical application of software engineering principles—such as API integration and data persistence—

but has also highlighted the critical importance of User Experience (UX) in security tools. A security tool is only effective if the analyst can understand its output, and BlueGuard's "Intelligence Stream" achieves exactly that.

7.4 Practical Impact and Future Direction

The successful completion of the BlueGuard platform provides a solid, context-aware foundation for modern digital security operations. It stands as a testament to the fact that modern security does not require multi-million dollar licenses, but rather a "Smart Orchestration" of existing open-source tools with AI intelligence. While the current version provides a highly capable monitoring environment, the project is designed with a future-proof roadmap. The architectural foundations laid here are ready for further enhancements, such as automated SOAR remediation, native mobile integration, and advanced historical trend analytics. Ultimately, BlueGuard represents a shift toward "Explainable Security," where every alert is accompanied by a logical reason, a strategic context, and a clear roadmap for remediation.

8. **BIBLIOGRAPHY**

- Flask Web Development Documentation: <https://flask.palletsprojects.com/>
- Tailwind CSS Framework Documentation: <https://tailwindcss.com/docs>
- MongoDB & PyMongo Official Documentation:
<https://www.mongodb.com/docs/drivers/pymongo/>
- Wazuh SIEM Rules & Webhook Integration:
<https://documentation.wazuh.com/current/user-manual/>
- MITRE ATT&CK Framework Reference: <https://attack.mitre.org/>
- Python requests Library for API Management: <https://requests.readthedocs.io/>
- "Understanding Alert Fatigue in SOCs" (Cybersecurity Context):
<https://www.ibm.com/topics/alert-fatigue>